Subscribe to DeepL Pro to translate larger documents.
Visit www.DeepL.com/pro for more information.

ISSN 1598-3986 (Print)

VOL. 36, NO. 3, June 2026

ISSN 2288-2715 (Online)

https://doi.org/10.13089/JKIISC.2026.36.3.935

Design and Security Validation of a Vision-Language Model-Based Image-Independent Visual Semantic Authentication (VSA) Framework

Jeong Pil-seong †‡

Myongji College (Professor)

Design and Security Validation of an Image-Agnostic Visual Semantic

Authentication (VSA) Framework Based on Vision-Language Models

Pil-seong Jeong†‡

Myongji College (Professor)

Abstract Abstract

Existing image-based graphic passwords are dependent on specific images and are vulnerable to image leaks and shoulder-surfing attacks. This paper proposes an image-agnostic Visual Semantic Authentication (VSA) framework that uses the “visual semantics” within an image—rather than the image itself—as a secret key. By combining Grounding DINO and CLIP, we extract information on objects, attributes, quantities, and 2x2 quadrant space; we simultaneously ensure security and availability through Flexible Range Logic and hash-based secret binding. After evaluating 1,009 images from the COCO 2017 benchmark across 16 policies at 5 difficulty levels, we observed a “security gradient” where the False Acceptance Rate (FAR) monotonically decreased from 51.73% to 0% as rule complexity increased. Furthermore, by automatically identifying positive images for each policy in the benchmark to evaluate FRR, we quantitatively demonstrated the security-usability trade-off between policy complexity and image availability.

ABSTRACT

Conventional graphical passwords are tied to specific images, making them vulnerable to image leakage and shoulder-surfing attacks. This paper proposes an Image-Agnostic Visual Semantic Authentication (VSA) framework that uses visual semantics within images as secret keys. The framework combines Grounding DINO and CLIP to extract objects, attributes, quantities, and 2x2 quadrant spatial information, while Flexible Range Logic and hash-based secret binding ensure both usability and server-opaque protection. Experiments on 1,009 COCO 2017 benchmark images across 16 security policies at five difficulty levels demonstrate a monotonic FAR gradient from 51.73% to 0% as rule complexity increases. FRR is also evaluated by automatically identifying positive images from the benchmark, and the trade-off between policy complexity and image availability is quantitatively characterized.

Keywords: Visual Semantic Authentication, Vision-Language Model, Graphical Password, Hash-based Secret Binding, Security Gradient

Received (February 23, 2026), Modified (April 2, 2026), Accepted (August 8, 2026)

† First author, ibetter.kr@gmail.com

‡ Corresponding author, ibetter.kr@gmail.com (Corresponding author)

I. Introduction

With the acceleration of digital transformation and the widespread adoption of remote services, the importance of user authentication continues to grow. Traditional text-based passwords face issues such as weak password selection and reuse due to users' cognitive load [1], while biometric authentication, although highly convenient, cannot be replaced if biometric data is compromised due to its irrevocability. Against this backdrop, graphical passwords—which leverage humans' superior visual memory—have been studied as an alternative since the early 2000s [2, 3]; however, even now, more than 20 years later, they have not been widely adopted in practical applications. The fundamental reason for this is that existing graphical passwords are dependent on specific images, making it difficult to ensure both security and usability simultaneously.

Most existing graphical password techniques suffer from the limitation of being image-dependent, relying on the pixel coordinates (click-points) of a specific image or the recognition of the image itself [4, 5]. This dependency entails two vulnerabilities. First, if the image used for authentication is leaked, the secret is directly exposed. Second, because users repeatedly select the same location on the same image, the system is vulnerable to shoulder-surfing attacks [6, 15]. Bonneau et al. [1] proposed a systematic comparison framework for web authentication techniques and pointed out that existing methods struggle to satisfy both security and usability simultaneously. Meanwhile, vision-language models (VLMs) have advanced rapidly, from CLIP (2021)[8] to Grounding DINO (2024)[9], enabling them to precisely understand the semantic content of images. These technological advancements enable meaning-based authentication—which was previously difficult to achieve—and provide a foundation for resolving the image dependency issue associated with graphic passwords.

To address these limitations, this paper proposes a Visual Semantic Authentication (VSA) framework that utilizes a Vision-Language Model (VLM). In VSA, the user secretly sets a visual semantic combination rule—such as "There are at least two dogs in the photo, and a red car is located in the upper-right corner"—and during

present any image that satisfies these rules. Since a different image can be used each time, the system is resilient to image leakage and observation attacks.

The distinctive contributions of this study are as follows.

- We designed a precise semantic authentication engine that combines Grounding DINO and CLIP—state-of-the-art VLM architectures—to extract objects, attributes, quantities, and spatial information in a multidimensional manner.
- We implemented an Independent Quadrant Analysis layer, which divides an image into four 2x2 quadrants for independent analysis, thereby achieving precise semantic extraction that aligns with the user's spatial perception without interference between regions and significantly expanding authentication entropy.
- We introduced Flexible Range Logic, which processes quantities as conditions (greater than, less than, equal to, etc.), and established a server-opaque security architecture in which the plaintext of secret rules is not stored on the server through hash-based secret binding.
- We quantitatively demonstrated the security gradient—the relationship between policy complexity and security performance—using large-scale benchmark data.

The structure of this paper is as follows: Chapter 2 analyzes related research, and Chapter 3 describes the proposed method in detail. Chapter 4 presents a security analysis, Chapter 5 presents the experimental results, and Chapter 6 concludes the paper.

II. Related Research

2.1 Graphic Password Authentication Techniques

Graphic passwords are an authentication method that leverages the user's visual memory to overcome the limitations of text-based passwords; they are broadly classified into recall-based, recognition-based, and cued-recall-based methods [2].

PassPoints, proposed by Wiedenbeck et al. [4], is a cue-recall-based technique in which users click specific points on an image; it demonstrated superior retention compared to text passwords. Subsequently, Chiasson et al. [5, 13] proposed cue-clicked points

(Cued Click-Points, CCP/PCPP), which presents a new image for each click, thereby mitigating the hotspot problem. However, these techniques all share the issue of image dependency. Since the image used for authentication is fixed, there is a risk that the click points or the selected image will be exposed if the image is leaked. Binbeshr et al. [6] conducted a systematic review of shoulder-surfing-resistant graphic password techniques and pointed out that eliminating image dependency is a key challenge for improving security.

Recently, research on graphic passwords utilizing deep learning has been actively underway. Ray et al. [7] proposed a GPOD system using object detection, while Dias et al. [18] proposed a deep learning-based shoulder-surfing defense technique, and Kausar et al.
[19] and Rasheed et al.[20] proposed hybrid authentication and handwriting recognition-based authentication, respectively. However, these techniques are also dependent on specific images, so security in the event of an image leak
. Olade et al. [14] proposed SemanticLock, which utilizes semantically linked image sequences, demonstrating the potential for semantic-level authentication; however, it remains dependent on a pre-registered set of images. Pritee et al. [21] conducted a systematic review of AI-based user authentication techniques and pointed out that robustness against adversarial attacks remains a challenge. Table 1 compares the characteristics of existing graphic password techniques.

Table 1. Comparison of Graphical Password Schemes

Scheme	Image -Agnostic	Shoulder -Surfing Resistant	Password Space
PassPoints [4]	No	Low	Medium
CCP/PCCP [5, 13]	No	Low	Medium
GPOD [7]	No	Medium	Medium
SemanticLock [14]	No	Medium	Medium
VSA (Proposed)	Yes	High	Very High

2.2 The Applicability of Vision-Language Models to Authentication

Vision-language models (VLM) are artificial intelligence models that simultaneously understand visual information and natural language, and they have recently seen rapid advancements.

CLIP (Contrastive Language-Image Pre-training), proposed by Radford et al. [8], performed contrastive learning using 400 million image-text pairs and achieved zero-shot capability, enabling the classification of visual concepts into natural language without predefined categories. Liu et al. [9] proposed Grounding DINO, which combines the DINO architecture with grounded pre-training, and achieved state-of-the-art performance in open-set object detection, where arbitrary objects are detected using natural language queries.

These advancements in VLMs open up new possibilities in the field of authentication. This paper presents a detailed
We design an authentication engine that extracts multidimensional semantic information from images by combining dense object detection capabilities with CLIP's visual attribute classification capabilities. This enables semantic authentication that goes beyond the level of image recognition.

2.3 Limitations of Previous Research

Existing research on graphic passwords and visual authentication shares the following
.

First, there is the issue of image dependency. Since existing methods use fixed authentication images, secrets are directly exposed if the images are leaked.

Second, there is a lack of authentication at the semantic level. Existing methods rely on pixel coordinates or image recognition and do not utilize the semantic content of images as a secret. Third, there is a trade-off between security and usability. According to an analysis by Bonneau et al. [1], it is extremely rare for existing authentication methods to satisfy both security and usability simultaneously.

The VSA proposed in this paper utilizes VLM to employ the semantic content of an image as the core of authentication, thereby ensuring image independence and simultaneously improving both security and usability.

III. Proposed Framework

This chapter describes in detail the overall structure and core components of the VSA framework.

3.1 System Architecture

Fig. 1 illustrates the VSA framework, which consists of an enrollment phase and a verification phase.

During the enrollment phase, when a user inputs a reference image, the system runs the VLM pipeline to extract object types, color/state attributes, quantity, and quadrant location information. The user selects 2–3 semantic facts from the extracted information and specifies a quantity operator (greater than, less than, equal to, etc.).

In the verification stage, the user presents an arbitrary image and a password that satisfy the secret rule. The system extracts meaning using the same VLM pipeline and performs verification by comparing the results with the stored hash value and quantity conditions.

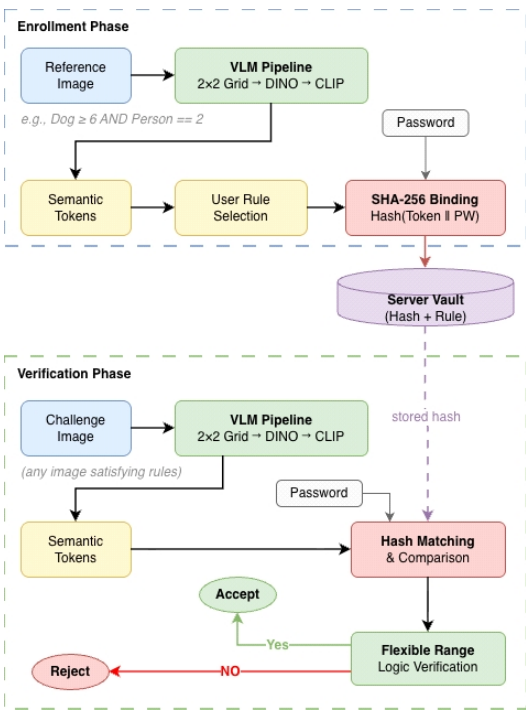


Fig. 1. Overall Process of the VSA Framework

3.2 Multidimensional Semantic Extraction Engine

3.2.1 Object Detection

Using the Grounding DINO-Base model [9], to detect objects within the image. This system uses 22 kernels

We define the "object" concepts (person, dog, cat, car, bus, bicycle, bag, shoes, laptop, cup, bottle, book, monitor, chair, table, bench, tree, plant, umbrella, glasses, horse, bird) as a "reliable concept set" and extract only the objects that correspond to these concepts. The 22 categories were selected from the 80 classes in the COCO dataset (1) Grounding DINO's detection precision is stable, and (2) they correspond to concrete objects that general users can routinely recognize and distinguish. This suppresses over-detection (hallucination) in VLM and ensures results that align with user perception. The detection confidence threshold was set to 0.45 for quadrant analysis and 0.35 for global analysis; objects with an area less than 5% of the analysis region and a confidence score below 0.6 are considered noise and removed.

3.2.2 Attribute Extraction

For each detected object, the CLIP-ViT-B/32 model [8] to classify visual attributes. After cropping the object's bounding box, we calculate the CLIP similarity for predefined attribute candidates (e.g., "a photo of a walking person," "a photo of a brown dog") based on the object category and select the attribute with the highest similarity.

3.2.3 Four-Quadrant Independent Space Analysis

The image is divided into four quadrants—top-left, top-right, bottom-left, and bottom-right—based on the horizontal and vertical centerlines. VSA analyzes each quadrant by cropping it as an independent session, thereby eliminating context interference from adjacent quadrants. This is referred to as Independent Quadrant Analysis and serves as a key mechanism for expanding authentication entropy by clearly distinguishing between the "dog in the top-left quadrant" and the "dog in the bottom-right quadrant." An example of the analysis process is shown in Fig. 2. Additionally, for each object, the system analyzes whether the bounding box touches the boundary of the cropped area to determine whether the object is fully visible or partially visible. The boundary margin is set to 5 pixels.

3.3 Semantic Token Normalization

The extracted semantic information is serialized into the canonical format shown in Table 2. The canonical string follows the format shown in Equation 1.

[illegible] (1)

The total count token aggregates the individual detection results for each quadrant on a label-by-label basis to accurately reflect the total number of objects in the entire image, and is generated according to the specifications in Equation 2.

[illegible] (2)

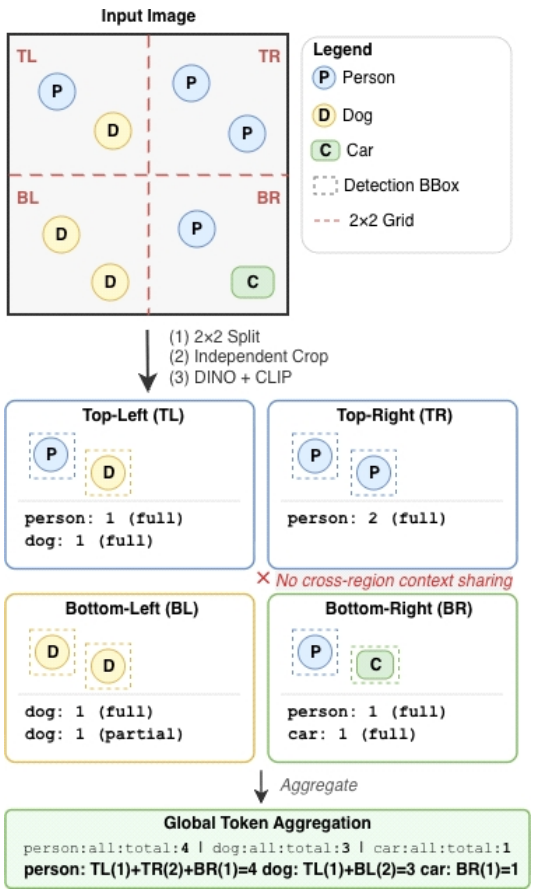


Fig. 2. Example of Independent Quadrant Analysis

3.4 Flexible Range Logic

Unlike existing authentication techniques that require only exact matches, VSA supports logical operators for quantities as shown in Table 3.

The user sets an operator and a target quantity for each semantic token. For example, "dogs >= 6" means that the condition is satisfied if there are at least six dogs in the image. This provides robust authentication even in the face of environmental changes (such as lighting, composition, or objects obscuring other objects), while also enhancing security by making it difficult for an attacker to deduce the exact rules (both the operator and the target value).

Table 2. VSA Semantic Token Schema

Field	Description	Example
category	Semantic category	object
core_concept	Object label	dog, person
position	Quadrant position	top-left, all
visibility	Visibility status	full, partial, total
Feature	Visual attribute	running, brown, total
count	Detected quantity	1, 2, 3

Table 3. Supported Logical Operators in Flexible Range Logic

Operator	Symbol	Description
Exactly	==	The count must equal the target
At least	>=	The count must be greater or equal
At most	<=	The count must be less than or equal
More than	>	The count must be strictly greater
Less than	<	Count must be strictly less

3.5 Hash-Based Secret Binding

For security reasons, the server does not store the plaintext of users' secret rules. Only the category, concept, location, visibility, and attributes of the semantic tokens are combined with the user's password, converted into a SHA-256 hash value, and then stored. Quantity-related information (operators, target values) is stored separately in metadata

for verification purposes. Therefore, while the server cannot restore the original object names from the hash, it retains the structure of the rules (operator types, target quantities, and number of rules).

This structure provides protection similar to the core property of zero-knowledge proofs (ZKP)[11]—secrecy—in that the server cannot know the user's secret (object name and attributes). However, since quantitative metadata (operators, target values) is stored in plaintext, the server possesses structural information indicating that "while it does not know which specific objects are involved, there must be at least two of them." This differs from the strict ZKP defined by Goldwasser et al. [11], in which "the verifier gains no information other than the validity of the proof." In this paper, we explicitly refer to this as "server-opaque" protection. While it is mathematically weaker than a strict ZKP, it represents a meaningful security improvement compared to existing graphical passwords, which store confidential information (images, click coordinates) on the server in plaintext or in a form that can be reverse-engineered. The storage structure is shown in Equation 3. Here, Ts is a normalized string of semantic tokens excluding the quantity, where s represents concept, p represents position, v represents visibility, and J represents feature.

$$T_s \approx s \| p \| v \| J \qquad h \approx SHA\text{—}Z^{(6)}(T_s \| \text{passmord}) \tag{3}$$

During authentication, the system uses tokens extracted from the input image to

It calculates the same hash for each token to find the one that matches the stored hash value, and then verifies whether the quantity of that token satisfies the stored logical conditions. Authentication is successful only when all conditions are satisfied simultaneously (AND logic).

For practical deployment, it is recommended to use Argon2id[10], a memory-hard key derivation function, along with a user-specific random salt to prevent offline brute-force attacks.

Ⅳ. Security Analysis

In this chapter, we evaluate the security of the proposed framework from the perspectives of theoretical analysis and attack resistance. We adopted the following three metrics, which are commonly used in international standard evaluation frameworks for authentication systems. First, secret space entropy is an information-theoretic metric that measures the theoretical strength of a secret; in NIST SP 800-63B [16], the authentication assurance level

It serves as the basis for determining the Authentication Assurance Level. Second, the False Acceptance Rate (FAR) is the probability that an unauthorized user will accidentally pass authentication; it is a key metric for quantifying the security strength of biometric authentication (ISO/IEC 19795-1[17]) and knowledge-based authentication systems. Third, the False Rejection Rate (FRR) is the probability that a legitimate user will fail authentication; together with the FAR, it determines the security-availability trade-off of an authentication system. The combination of these three metrics has been adopted as a key evaluation factor in the security dimension within the authentication technique comparison framework proposed by Bonneau et al. [1], and we quantitatively validate it in the experiments in Chapter 5.

4.1 Secret Space and Entropy Analysis

The secret space of a VSA is determined by the combination of semantic rules selected by the user. A single semantic rule consists of a combination of object type (O), spatial location (P), attribute (A), and logical operator (L). The entropy C of a VSA secret consisting of n rules is given by Equation 2.

$$C \approx \sum_{i=1}^{n} \log_Z(O_i \times P_i \times A_i \times L_i \times C_i) + C_{pm} \tag{4}$$

Here, O denotes the object space (22 types), and P

denotes the position space (4

Domain + Global = 5), A represents the attribute space (approximately 7 types), L represents logical operators (5 types), C is the range of values (effectively 1–20 = 20), and C_{pm} is password entropy.

Assuming that the selection of each element follows a uniform distribution, the upper bound on the entropy of a single rule is $\log_2(22 \times 5 \times 7 \times 5 \times 20) = \log_2(77{,}000) \approx 16.26$

It is a bit. When combining the two rules, approximately 32.46 bits of entropy can be achieved; including a password (approximately 47.6 bits based on an 8-character alphanumeric string), a total of over 80 bits of entropy can be secured. This significantly exceeds the secret space of existing graphic passwords (PassPoints 5 clicks: approximately 43 bits[2]).

However, actual users are likely to select familiar objects (such as people, dogs, or cats) in a biased manner. For example, in a biased scenario where 80% of selections are concentrated on the top five objects, the effective entropy of the object space decreases from $\log_Z \approx 4.46$ bits to approximately 2.8 bits, and the total entropy based on the two rules plus the password drops to approximately 63 bits. While this still exceeds that of PassPoints (43 bits)

, but since there is a significant difference from the upper bound (80 bits) assumed under a uniform distribution, further research on the actual object selection distribution of real users is needed.

4.2 Attack Resistance Analysis

Table 4 compares and analyzes the resistance of VSA to major attack types against existing methods. PP stands for PassPoints, CCP stands for Cued Click-Points, PCCP stands for Persuasive Cued Click-Points, "Crit" stands for Critical, and "Med" stands for Medium. In terms of resistance to shoulder surfing, since VSA allows users to use a different image each time, an attacker cannot infer the actual "meaning rule" even if they observe the authentication process. It is recommended not to use the same image more than once.

Regarding image leakage immunity, since the secret in VSA is the "meaning rule" rather than the image itself, the secret remains secure even if the image used for authentication is leaked. This is a fundamental difference from existing graphic passwords.

In terms of brute-force resistance, as analyzed in Section 4.1, a combination of two rules and a password yields entropy of approximately 80 bits or more. In the experiments described in Chapter 5, where 16 policies were evaluated, a combination of two rules AND achieved an average FAR of 1.74%, while a combination of three rules achieved 1.19%.

Regarding resistance to server compromise, only hash values and logical rules (operators, quantities) are stored on the server; the original object names or attribute information are not stored. Therefore, even if the server is compromised, an attacker cannot reverse-engineer the hash to reconstruct the user's semantic rules. However, since the current prototype uses the general-purpose hash function SHA-256, GPU-based offline attacks can perform billions of hash calculations per second. Since the input space for semantic tokens is limited (22 object categories), Argon2id[10] and a user-specific random salt must be applied during practical deployment to sufficiently increase the cost of offline attacks.

Regarding replay resistance, since a different image is used each time, replaying an image from a previous authentication session is meaningless. Because meaning is extracted from the input image in real time for verification, attacks that reuse stored responses are blocked.

Finally, regarding the threat of adversarial attacks against VLM, since VSA uses the VLM's detection results as the basis for verification, it is theoretically possible to launch attacks that intentionally manipulate the VLM's detection results through adversarial patches or input perturbations. To address this, future research should explore the verification of the integrity of input image preprocessing, cross-validation using multiple VLM ensembles, or the introduction of robust detection models trained using adversarial training.

V. Experimental Results and Analysis

5.1 Experimental Environment

To verify the security performance of the proposed method, experiments were conducted in the environment shown in Table 5.

Table 4. Comparison of Attack Resistance

Attack Type	PassPoints [4]	CCP/ PCCP [5, 13]	VSA (Proposed)
Shoulder Surfing	Weak	Weak	Strong
Image Leakage	Critical	Critical	Immune
Brute-force	Medium	Med	Strong
Server Compromise	Critical	Critical	Strong
Replay Attack	Weak	Weak	Strong

Table 5. Experimental Setup

Component	Specification
Object Detection	Grounding DINO-Base [9]
Attribute Model	CLIP-ViT-B/32 [8]
Hardware	Apple M3 Pro (36GB unified memory)
Acceleration	MPS (Metal Performance Shaders)
Framework	PyTorch 2.10, Transformers 5.1
Language	Python 3.12

The experimental dataset consisted of a total of 1,009 negative samples—comprising 1,000 images randomly sampled from the COCO 2017 Validation Set [12] and 9 manually collected images—and 6 positive samples.

Each policy was evaluated in two modes—global analysis and quadrant-independent analysis—resulting in a total of 32 experiments (16 policies × 2 modes). Considering the high computational cost of VLM inference (approximately 1–5 seconds per image), we constructed a three-stage pipeline that caches detection results. (1) Caching VLM inference results by mode, (2) Batch evaluation of policies from the cache,
(3) Statistical analysis based on the Clopper-Pearson exact binomial confidence interval. Through this approach, VLM inference was performed only twice (once globally
+ 1 in the fourth quadrant) while efficiently conducting 32 policy evaluations.

5.2 Security Policy Design

Since a single extreme policy alone cannot verify the full spectrum of security, we systematically designed 16 security policies across five difficulty levels. Table 6 shows the rule composition for each policy. During policy design, we systematically varied the following factors: (1) number of rules (1–3), (2) logical operators (range ≧, exact ==, upper bound ≦), (3) object frequency (high-frequency "person" to low-frequency "bird," "cat"), and (4) quantity threshold (1–6). P01 is a baseline expected to yield a high FAR, using the most frequent object (person) in the COCO dataset in a single rule, while P10 provides an upper bound benchmark approaching a 0% FAR through an extreme combination. It is designed to verify the entire range of security gradients by including various patterns, such as low-frequency objects alone (P11: Bird ≥ 1), upper bound operators (P13: Person ≤ 2), and combinations of three rules (P08, P15).

5.3 Multi-Policy FAR Analysis

Table 7 shows the FAR and 95% confidence intervals for the 16 policies in both global and quadrant modes. The confidence intervals were calculated using the Clopper-Pearson exact binomial method based on $N_{neg} \approx 1{,}009$ speech samples. A security gradient—where the FAR monotonically decreases with policy complexity—was clearly observed across all 16 policies. The simple policy with a single rule (P01: Person≧1) had a global FAR of 51.73%, leaving it virtually unprotected, whereas the FAR dropped sharply to between 0.20% and 6.24% for policies with two rules combined using an AND operator, and for policies with three or more rules (P08, P15), the FAR

Table 6. Security Policy Design (16 Policies, 5 Difficulty Levels)

ID	Difficulty	Rules	N
P01	Easy	Person >= 1	1
P02	Easy	Chair >= 1	1
P03	Medium-Easy	Person >= 3	1
P04	Medium-Easy	At least 1 person and at least 1 car	2
P05	Medium	Person >= 1 and Dog >= 1	2
P06	Medium	Person >= 1 and Car >= 2	2
P07	Medium-Hard	Person == 2 and Dog >= 1	2
P08	Medium-Hard	Person >= 1 and Bird >= 2 and Tree >= 1	3
P09	Hard	Person == 1 and Dog >= 3	2
P10	Hard	Person == 2 and Dog >= 6	2
P11	Easy	Bird >= 1	1
P12	Medium-Easy	Person >= 1 and Chair >= 1	2
P13	Medium	Person <= 2 and Dog >= 1	2
P14	Medium	Cat >= 1 and Chair >= 1	2
P15	Medium-Hard	Person >= 2 And Car >= 1 And Tree >= 1	3
P16	Hard	Bird >= 1 And Cat >= 2	2

Table 7. FAR Comparison by Policy and Analysis Mode ($N_{neg} \approx 1{,}009$)

ID	Diff.	Global FAR (%)	Global 95% CI	Quadrant FAR (%)	Quadrant 95% CI
P01	Easy	51.73	[48.60, 54.86]	47.18	[44.06, 50.31]
P02	Easy	10.21	[8.41, 12.24]	7.33	[5.80, 9.12]
P03	Medium-Easy	19.03	[16.65, 21.59]	22.30	[19.77, 25.00]
P04	Medium-Easy	4.96	[3.70, 6.48]	1.88	[1.14, 2.93]
P05	Medium	1.49	[0.83, 2.44]	1.29	[0.69, 2.19]
P06	Medium	2.87	[1.93, 4.10]	0.69	[0.28, 1.42]
P07	Medium-Hard	0.20	[0.02, 0.71]	0.59	[0.22, 1.29]
P08	Medium-Hard	0.10	[0.00, 0.55]	0.00	[0.00, 0.36]
P09	Hard	0.00	[0.00, 0.36]	0.00	[0.00, 0.36]
P10	Hard	0.00	[0.00, 0.36]	0.00	[0.00, 0.36]
P11	Easy	2.38	[1.53, 3.52]	2.48	[1.61, 3.64]
P12	Medium-Easy	6.24	[4.83, 7.92]	3.96	[2.85, 5.36]
P13	Medium	0.99	[0.48, 1.82]	1.09	[0.55, 1.94]
P14	Medium	0.59	[0.22, 1.29]	0.50	[0.16, 1.15]
P15	Medium-Hard	2.25	[1.45, 3.40]	0.30	[0.06, 0.87]
P16	Hard	0.10	[0.00, 0.55]	0.20	[0.02, 0.71]

The results ranged from 0.10% to 2.28%. In particular, P16 (Bird≧1 AND Cat≧2), which utilized low-frequency objects, achieved a FAR of 0.10% with only two rules, confirming that the natural occurrence frequency of objects directly affects the FAR. Practical, moderate-difficulty policies also demonstrated effective security. P04 (Person≧1 AND Car≧1) achieved a global FAR of 4.96%, while P14 (Cat≧1 AND Chair≧1) achieved 0.59%, showing that sufficient security can be ensured without relying on extreme policies. Furthermore, P13 (Person ≤ 2 AND Dog ≥ 1), which utilizes an upper bound operator, recorded a global FAR of 0.99%, confirming the effectiveness of various operator combinations.

5.4 Comparison of Global vs. Quadrant Analysis Modes

Comparing the two modes in Table 7, the FAR in the 4-quadrant mode was lower than that of the global mode in 9 out of 16 policies, the same in 2, and lower in the global mode in 5. In P15, the 4-quadrant FAR of 0.30% represents an approximately 7.6-fold improvement compared to the global FAR of 2.28%, and in P06, there was an approximately 4.2-fold improvement (2.87% → 0.69%), confirming that quadrant-independent analysis contributes to improved security in multi-rule policies. In contrast, for P03 and P07, the quadrant FAR was higher than the global FAR; this is attributed to the double detection of objects straddling quadrant boundaries, as well as the exact equality operator (==) being sensitive to fluctuations in quantity caused by partitioning. Statistical significance tests (such as the McNemar test) for the FAR difference between the two modes need to be verified in future large-scale experiments. In terms of computational efficiency, the average inference time for the global mode was 1.32 seconds, whereas the quadrant mode, which processes four independent crops sequentially, took an average of 4.78 seconds (3.63 times longer).

5.5 FRR and Image Availability Analysis

To quantitatively evaluate the False Rejection Rate (FRR), images that satisfied each policy were automatically identified from the 1,009 images in the COCO benchmark and used as positive samples. Table 8 shows the number of positive images (image availability) for each policy and the upper bound of the Clopper-Pearson 95% confidence interval for the FRR. The "Image Availability" in Table 8 serves as an indirect indicator of the difficulty users face when searching for images for authentication. The average availability for the "Easy" difficulty level was 21.44%, indicating that images are easy to find, whereas for the "Hard" difficulty level, it was 0.03%, requiring a pre-prepared set of images. The FRR recorded 0% for all policies in cache-based verification, and for policies with sufficient positive samples (P01: $N_{pos} \approx$ ZZ), the upper bound of the 95% CI for FRR

Table 8. Image Availability and FRR Analysis (Global Mode, N=1,009)

ID	Diff.	Matching Images	Availability Rate (%)	95% Upper FRR CI (%)
P01	Easy	522	51.73	0.70
P02	Easy	102	10.21	3.52
P03	Medium-Easy	192	19.03	1.90
P04	Medium-Easy	50	4.96	7.11
P05	Medium	15	1.49	21.80
P06	Medium	29	2.87	11.94
P07	Medium-Hard	2	0.20	84.19
P08	Medium-Hard	1	0.10	97.50
P09	Hard	0	0.00	-
P10	Hard	0	0.00	-
P11	Easy	24	2.38	14.25
P12	Medium-Easy	63	6.24	5.69
P13	Medium	10	0.99	30.85
P14	Medium	6	0.59	45.93
P15	Medium-Hard	23	2.28	14.82
P16	Hard	1	0.10	97.50

This narrowed to 0.70%, confirming a practically low FRR. Under policies with a shortage of positive samples, the CI is wide, so the real-world FRR needs to be verified in future usability studies. For practical deployment, the "Medium" difficulty level (FAR 0.5%–2.9%, availability 0.6%–2.9%) represents a balance between security and usability.

5.6 Security Analysis by Factor

We analyzed the impact of policy design factors on the FAR. Tables 9 and 10 show the number of rules and the average FAR.

The global average FAR ranged from 20.84% for 1 rule to 2 rules AND combination, it decreased by approximately 12 times to 1.74%, and further decreased to 1.19% with three rules. The FAR also showed a monotonic decrease by difficulty level, from Easy (21.44%) to Hard (0.03%), confirming the systematic nature of the policy design. Policies containing the exact match operator (==) (P07, P09, P10) had a lower FAR than policies using the range operator (≧) at similar difficulty levels, and P13, which used the upper bound operator (≦), also recorded a global FAR of 0.99%, confirming the effectiveness of various operator combinations. In terms of object frequency, high-frequency objects

Table 9. Mean FAR by Number of Rules

N	Policies	Global Mean FAR (%)	Quadrant Mean FAR (%)
1	P01, P02, P03, P11	20.84	19.82
2	P04–P07, P09–P10, P12–P14, P16	1.74	1.02
3	P08, P15	1.19	0.15

Table 1. Mean FAR by Difficulty Level

Rules	Policies	Global Mean FAR (%)	Quadrant Mean FAR (%)
Easy	P01, P02, P11	21.44	19.00
Meidum -Easy	P03, P04, P12	10.08	9.38
Medium	P05, P06, P13, P14	1.49	0.89
Medium -hard	P07, P08, P15	0.86	0.30
Hard	P09, P10, P16	0.03	0.07

Table 1.1. Computation Cost Comparison

Scheme	Model size	Inference Memory	Authentication Time (Mean)	Hardware Requirements
PassPoints [4]	-	< 10MB	< 0.01 sec	CPU
CCP/PCCP [5, 13]	-	< 10MB	< 0.01 sec	CPU
GPOD [7]	~100MB	~100MB	~0.5 sec	GPU recommended
VSA (Global)	~800 MB	~4 GB	1.32 sec	GPU/NPU
VSA (Quadrant)	~800 MB	~4 GB	4.78 sec	GPU/NPU

Table 1 2. Comparison with Existing Authentication Schemes Based on the Bonneau et al. Framework

Property	Text PW	PassPoints [4]	PCCP [5, 13]	VSA (Proposed)
Memory-Effortless	No	Quasi	Quasi	-
Nothing to Carry	Yes	Yes	Yes	Yes
Easy to Learn	Yes	Quasi	Quasi	-
Resilient to Physical Observation	No	No	No	Yes
Resilient to Theft	No	No	No	Yes
No-Trusted-Third-Party	Yes	Yes	Yes	Yes
Password Space (bits)	~47	~43	~43	~80+

While the FAR of P01, which used common objects (person: 52%), was 51.73%, that of P11, which included low-frequency objects (bird: 2.4%), was 2.38%, indicating that natural occurrence frequency had a direct impact on the FAR.

5.7 Computational Cost Analysis

Since VSA uses VLM-based meaning extraction, it incurs higher computational costs compared to existing graphic passwords. Table 11 compares the computational costs of each method.

The total model size of VSA is approximately 800 MB, and it uses approximately 4 GB of GPU memory during inference. The average authentication time of 1.32 seconds in global mode falls within the typical response time for web authentication (2–5 seconds), making it suitable for real-time authentication. Although the time in quadrant mode is somewhat higher at 4.78 seconds, it can theoretically be reduced to the level of global mode by processing the four independent crops in parallel. Existing coordinate-based methods (PassPoints, CCP/PCCP) can achieve millisecond-level responses through simple coordinate comparison, but they suffer from the security limitation of image dependency. The computational cost of VSA is a trade-off for the security benefit of image independence, and this can be improved in the future through optimization using lightweight VLMs (such as DINO-Tiny, MobileCLIP, etc.) or through optimization using mobile NPUs.

5.8 Comparison with Existing Methods

Table 12 compares the proposed method with existing approaches, drawing on the authentication method comparison framework by Bonneau et al. [1]. The proposed method outperforms existing graphic passwords in terms of resistance to physical observation (shoulder surfing) and resistance to theft (image leakage), and its secret space is more than twice as large. Based on the security metrics confirmed in this experiment, it has been quantitatively demonstrated that a security level with a False Acceptance Rate (FAR) of 5% or lower can be achieved even with a 2-rule policy at a practical difficulty level.

Ⅵ. Conclusion

This paper proposes an image-independent visual semantic authentication (VSA) framework that utilizes visual meaning within images as a secret key by leveraging vision-language models, and demonstrates its security. The proposed method consists of a multidimensional semantic extraction engine combining Grounding DINO and CLIP, a four-quadrant independent space analysis, flexible range logic, and hash-based secret

binding. By treating "meaning"—rather than the image itself—as the secret, VSA achieves structural resilience against image leakage and shoulder-surfing attacks, which are vulnerabilities of existing graphic passwords.

Across 1,009 images from an official benchmark, the system achieved a 5-level difficulty rating

The evaluation of 16 policies in global and quadrant modes revealed a security gradient where the False Acceptance Rate (FAR) decreased monotonically from 51.73% to 0% as rule complexity increased, and demonstrated that quadrant-independent analysis improves security for most policies. We demonstrated that commercial-grade security (FAR < 5%) can be achieved with just two or more combinations of semantic rules, and confirmed the feasibility of real-time authentication with an average inference time of 1.32 seconds in global mode and 4.78 seconds in quadrant mode. Furthermore, in the COCO benchmark, we automatically identified positive images for each policy to evaluate FRR. We found an upper bound of 0.70% for the FRR 95% CI in policies with sufficient positive samples (P01: $N_{\text{pos}} \approx$ ZZ) and quantitatively presented the trade-off between policy complexity and image availability.

However, this study has the following limitations. First, the positive samples used for FRR evaluation were automatically filtered from the COCO dataset and thus do not reflect the non-deterministic nature of VLM re-inference. Second, usability attributes (ease of memorization, ease of learning) were indirectly evaluated through image availability simulations, but no empirical validation involving actual users was conducted. Third, the computational cost of VLM-based authentication (model ~800 MB, authentication 1.32–4.78 seconds) is higher than that of existing coordinate-based methods, and model lightweighting is necessary.

To address these limitations, we plan to conduct the following in future research. First, we will conduct a usability study with real users. We plan to recruit at least 30 participants to measure registration time, authentication time, memory retention after 1 week and 4 weeks, ease of learning, and SUS scores, and to validate the real-world FRR in a VLM re-inference environment. Second, we will expand the secret space by introducing Semantic Relationship Logic, which utilizes relationships between objects as secret keys. Third, we will explore the optimal balance between security and efficiency by comparing the current 2x2 quadrant-based analysis with various spatial partitioning strategies, such as 3x3 grids, non-uniform partitioning, or image-content-based adaptive partitioning. Fourth, we will utilize lightweight VLMs (DINO-Tiny, MobileCLIP) or mobile NPUs to

.

References

[1] J. Bonneau, C. Herley, P.C. van Oorschot, and F. Stajano, "The quest to replace passwords: a framework for comparative evaluation of web authentication schemes," Proc. IEEE Symposium on Security and Privacy (S&P), pp. 553–567, May 2012.

[2] R. Biddle, S. Chiasson, and P.C. van Oorschot, "Graphical passwords: learning from the first twelve years," ACM Computing Surveys, vol. 44, no. 4, pp. 1–41, Sept. 2012.

[3] X. Suo, Y. Zhu, and G.S. Owen, "Graphical passwords: a survey," Proc. 21st Annual Computer Security Applications Conference (ACSAC), pp. 463–472, Dec. 2005.

[4] S. Wiedenbeck, J. Waters, J.C. Birget, A. Brodskiy, and N. Memon, "PassPoints: Design and Longitudinal Evaluation of a Graphical Password System," International Journal of Human-Computer Studies, vol. 63, no. 1-2, pp. 102–127, July 2005.

[5] S. Chiasson, P.C. van Oorschot, and R. Biddle, "Graphical Password Authentication Using Cued Click Points," ESORICS 2007, LNCS 4734, pp. 359–374, 2007.

[6] F. Binbeshr, K.C. Siong, L.Y. Por, M. Imam, A.A. Al-Saggaf, and A.A. Abudaqa, "A systematic review of graphical password methods resistant to shoulder-surfing attacks," International Journal of Information Security, vol. 24, no. 1, Article 46, Feb. 2025.

[7] P. Ray, D. Giri, W. Meng, and S. Hore, "GPOD: an efficient and secure graphical password authentication

system using fast object detection," *Multimedia Tools and Applications*, vol. 83, no. 19, pp. 56569–56618, June 2024.

[8] A. Radford, J.W. Kim, C. Hallacy, A. Ramesh, G. Goh, S. Agarwal, G. Sastry, A. Askell, P. Mishkin, J. Clark, G. Krueger, and I. Sutskever, "Learning transferable visual models from natural language supervision," Proc. International Conference on Machine Learning (ICML), pp. 8748–8763, July 2021.

[9] S. Liu, Z. Zeng, T. Ren, F. Li, H. Zhang, J. Yang, Q. Jiang, C. Li, J. Yang, H. Su, J. Zhu, and L. Zhang, "Grounding DINO: Marrying DINO with Grounded Pre-training for Open-Set Object Detection," ECCV 2024, LNCS 15105, pp. 38–55, 2024.

[10] A. Biryukov, D. Dinu, and D. Khovratovich, "Argon2: New Generation of Memory-Hard Functions for Password Hashing and Other Applications," Proc. IEEE European Symposium on Security and Privacy (EuroS&P), pp. 292–302, Mar. 2016.

[11] S. Goldwasser, S. Micali, and C. Rackoff, "The knowledge complexity of interactive proof systems," SIAM Journal on Computing, vol. 18, no. 1, pp. 186–208, Feb. 1989.

[12] T.-Y. Lin, M. Maire, S. Belongie, J. Hays, P. Perona, D. Ramanan, P. Dollár, and C.L. Zitnick, "Microsoft COCO: Common Objects in Context," ECCV 2014, LNCS 8693, pp. 740–755, 2014.

[13] S. Chiasson, A. Forget, R. Biddle, and P.C. van Oorschot, "Influencing users toward better passwords: persuasive cued click-points," Proc. 22nd British HCI Group Annual Conference, pp. 121–130, Sept. 2008.

[14] I. Olade, H.-N. Liang, and C. Fleming, "Story-based authentication for mobile devices using semantically-linked images," International Journal of Human-Computer Studies, vol. 171, Article 102967, Mar. 2023.

[15] S. Wiedenbeck, J. Waters, L. Sobrado, and J.C. Birget, "Design and evaluation of a shoulder-surfing-resistant graphical password scheme," Proc. Working Conference on Advanced Visual Interfaces (AVI), pp. 177–184, May 2006.

[16] NIST, "Digital Identity Guidelines: Authentication and Authenticator Management," NIST Special Publication 800-63B-4, July 2025.

[17] ISO/IEC, "Information technology—Biometric performance testing and reporting—Part 1: Principles and framework," ISO/IEC 19795-1:2021, May 2021.

[18] N.I. Dias, M.S. Kumaresan, and R.S. Rajakumari, "A Deep Learning-Based Graphical Password Authentication Approach Against Shoulder-Surfing Attacks," Multiagent and Grid Systems, vol. 19, no. 1, pp. 99–115, Feb. 2023.

[19] N. Kausar, I.U. Din, M.A. Khan, A. Almogren, and B.-S. Kim, "GRA-PIN: A Graphical and PIN-Based Hybrid Authentication Approach for Smart Devices," Sensors, vol. 22, no. 4, Article 1349, Feb. 2022.

[20] A.F. Rasheed, M. Zarkoosh, and F.R. Elia, "Enhancing a graphical password authentication system with deep learning-based Arabic digit recognition," International Journal of Information Technology, vol. 16, no. 3, pp. 1419–1427, Mar. 2024.

[21] Z.T. Pritee, M.H. Anik, S.B. Alam,

J.R. Jim, M.M. Kabir, and M.F. Mridha, “Machine Learning and Deep Learning for User Authentication and Authorization in Cybersecurity: a state-of-the-art review," Computers & Security, vol. 140, Article 103747, May 2024.

<About the Authors>



Pil-seong Jeong, Full Member

February 2004: B.S. in Electrical Engineering, Seoul National University of Science and Technology

August 2008: Master of Science in Electronic and Telecommunications Engineering, Kwangwoon University

August 2013: Ph.D. in Electronic and Telecommunications Engineering, Kwangwoon University

March 2018–Present: Professor, Department of Information and Communication Engineering, Myongji College

<Research Interests> User authentication, visual authentication, vision-language models, IoT security, edge AI